

Phishing Email Analysis

PayPal-Themed Phishing Email Investigation

Final Incident Report

Portfolio Cybersecurity Investigation

1. Executive Summary

This investigation analyzed a suspicious email impersonating PayPal. The message used an urgent account-suspension theme, suspicious sender infrastructure, missing email-authentication results, and multiple suspicious URLs. The combined evidence supports classification of the message as a phishing attempt designed to impersonate PayPal and solicit sensitive information.

2. Objective

The objective was to examine the email headers, authentication information, originating infrastructure, URLs, transmission path, social-engineering indicators, and available threat-intelligence results, then document the findings as a professional phishing-email investigation.

3. Email Details

Subject: URGENT: Your PayPal Account Has Been Suspended

From: security@paypa1-secure.com

Reply-To: support@paypa1-recovery.tk

Return-Path: bounce@spam-relay.xyz

Originating IP: 91.234.56.78

Timestamp: 2025-01-15T14:23:11Z

Attachment: None identified

4. Header Analysis

The sender address uses the look-alike domain paypa1-secure.com, where the numeral “1” replaces the letter “l” in PayPal. The Reply-To and Return-Path use different domains, creating additional inconsistencies. No Message-ID was identified in the analysis.

5. Authentication Analysis

SPF: None

DKIM: None; 0 signatures

DMARC: None

No successful authentication results were identified in the analyzed email.

6. IP and Network Analysis

Originating IP: 91.234.56.78. VirusTotal showed 0 detections at the time of analysis; this does not establish that the IP is legitimate or safe. Reverse DNS was not identified. The transmission data also displayed 192.168.1.100, which is a private/internal address and is not treated as the public originating IP.

7. URL Analysis

Four URLs were identified. The paypa1-secure.tk URLs had 0/91 VirusTotal detections in the observed results. The TinyURL and Bitly links each had 1/95 detections and were identified as phishing by the displayed sources. The URLs were analyzed as indicators; suspicious links should not be opened directly.

8. Transmission Analysis

The displayed transmission path contained seven hops, including origin.paypa1-secure.com, internal.paypa1-secure.com, smtp.paypa1-secure.com, mail-gateway.xyz, compromised-server.cn, unknown-host.ru, spam-relay.xyz, and the final internal/private hop. The presence of a hostname such as compromised-server.cn is documented as displayed evidence; it does not independently prove that the server was actually compromised.

9. Social Engineering Indicators

The email used urgency and pressure: an account-suspension warning, a 24-hour deadline, and a final-notice theme. It requested sensitive information including a password, credit-card details, billing information, and SSN, and offered a \$50 reward incentive. These elements are consistent with credential and financial-information phishing behavior.

10. Indicators of Compromise

Email addresses: security@paypa1-secure.com; support@paypa1-recovery.tk; bounce@spam-relay.xyz

IP: 91.234.56.78

Domains: paypa1-secure.com; paypa1-secure.tk; paypa1-recovery.tk; spam-relay.xyz

URLs: paypa1-secure.tk/verify; www.paypa1-secure.tk; tinyurl.com/verify-account; bit.ly/paypal-unlock

11. MITRE ATT&CK; Mapping

T1566.002 — Phishing: Spearphishing Link

T1036 — Masquerading

No attachment-based phishing technique was mapped because no attachment was identified.

12. Key Findings

- PayPal-themed impersonation using look-alike domains.
- Sender, Reply-To, and Return-Path domains are inconsistent.
- No SPF, DKIM, or DMARC authentication result was identified.
- Multiple suspicious URLs were present.
- Two URL indicators had observed phishing detections.
- Strong urgency and requests for sensitive information were present.
- No attachment was identified.

13. Final Assessment

The combined evidence supports classifying the email as a phishing attempt impersonating PayPal. The conclusion is based on the sender-domain impersonation, inconsistent routing addresses, absent authentication results, suspicious URLs, and social-engineering characteristics.

14. Recommendations

Block or quarantine identified malicious indicators where appropriate. Educate users to verify account warnings through known official channels rather than email links. Monitor related sender addresses, domains, URLs, and infrastructure. Preserve the documented IOCs and investigate further if credentials or financial information were submitted.

15. Case Closure

Investigation completed and documented. No attachment was identified. The available header, authentication, URL, network, transmission, IOC, and social-engineering evidence was reviewed. Threat-intelligence results may change over time, so observed results represent the state at the time of analysis.

16. Privacy and Disclaimer

Before publishing evidence publicly, remove personal email addresses, passwords, API keys, authentication tokens, cookies, private mailbox data, and unrelated sensitive information. This report is a cybersecurity portfolio investigation and is not an official incident-response determination.